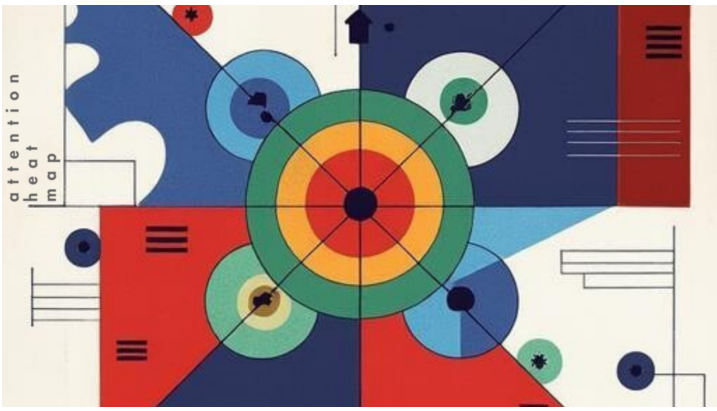
Home My Network Jobs Messaging Notifications 25 Me For Business Learning



https://www.redbubble.com/i/framed-print/Attention-Heatmap-Visualization-by-syncware/179000487.AJ1A3

AI Compliance in the Age of "I Don't Know Why"

Andrew Storms
VP of Security | AI Security Governance | Enterprise Risk & Compliance | Trusted Advisor to CEOs & Boards

March 6, 2026

The auditor asked a simple question: "Can you explain why your system accessed this customer's data?"

I had the logs. I had the timestamps. I had the agent's actions documented in perfect detail. What I didn't have was an answer to "why."

"The AI agent determined it was contextually relevant to the user's task" is technically accurate. It's also not going to satisfy an auditor.

The Compliance Framework We Built Assumes We Can Explain Our Systems

SOC 2, HIPAA, PCI-DSS, GDPR. Every major compliance framework requires you to prove not just *what* your systems did, but *why* they did it. Access to sensitive data? You need to justify it was necessary. Code changes to production? You need to show independent review. Security incident? You need to explain what happened and demonstrate your controls worked as designed.

The frameworks assume deterministic systems with explainable decision making. We're deploying AI agents that are neither.

I've written about how AI agents broke our supply chain security and killed predictable infrastructure. Now we're facing the reality that they may make traditional compliance frameworks unworkable.

The Three Compliance Gaps AI Agents Create

Gap 1: Segregation of Duties Becomes Meaningless

If one AI writes code and a different AI reviews it, did we achieve segregation of duties? Auditors look for independent actors with different motivations and judgment. AI agents have training data, not

motivations. If both learned from similar datasets, where's the meaningful separation? When AI Agent A approves AI Agent B's work, we're separating compute instances, not decision making.

Gap 2: Audit Trails Document Actions, Not Reasoning

Your logs show every API call, every timestamp, every action. What they don't show is *why*. Why did the agent determine that data access was necessary? Why did it call that specific service? AI agents make thousands of contextual decisions that never get documented. Traditional audit trails capture who, what, when, where. They assume the "why" is obvious or documented elsewhere. With AI agents, the "why" doesn't exist anywhere.

Gap 3: "Appropriate Access" Cannot Be Defined

Least privilege assumes you can enumerate what a system needs to do and grant minimum permissions. AI agents need access to whatever might be relevant. The agent summarizing documents might decide to cross-reference customer data. The agent drafting emails might check financial reports. Every decision is defensible in isolation. "Was this access appropriate?" is impossible to answer when you don't know what the agent will need until it decides it needs it.

What Auditors Actually Ask (And What We Can't Answer)

"Why did your system access this patient's data?" *"The AI agent determined it was contextually relevant."* Can you prove that access met HIPAA's minimum necessary standard? No. You have logs showing what was accessed, not why it was necessary.

"Does AI code review satisfy segregation of duties?" *"Different AI agents, different model versions."* Are they truly independent if they're trained on similar data and optimized for similar objectives? We don't know. Neither does the AICPA.

"Explain how this security incident occurred." *"Each agent performed correctly. The exploit emerged from how they interacted."* What control failed? None individually. The attack existed at the system level, not the component level.

The Real World Impact

Your AI medical assistant accessed 47 patient records to answer a clinical question. It produced excellent guidance. But you can't prove each access was minimum necessary. HIPAA doesn't care about good results. It cares about justifiable access.

Your SOC 2 auditor can't determine if AI code review satisfies segregation of duties. Neither can the AICPA. Your report gets qualified.

Payment data was exfiltrated through an agent cascade. Every agent's logs show routine operations. Forensics can't explain how the breach occurred. PCI-DSS requires you to demonstrate effective controls. You can show what each agent did. You can't explain why it resulted in data theft.

What Organizations Are Actually Doing

Option 1: The Conservative Position Treat AI as advisory only for regulated functions. "AI recommends, human approves" at least gives you a person to point to when auditors ask who made the decision. This

satisfies compliance frameworks. It also destroys the value proposition of autonomous agents.

Option 2: The Documentation Theater Implement semantic logging that captures the agent's stated reasoning. Log not just API calls but intent: "Agent accessed patient data to validate treatment contraindications." You still can't prove the access was truly necessary, but at least you have something to show auditors. It documents the opacity without solving it.

Option 3: The Risk Based Compromise Deploy AI agents for low risk functions, require human oversight for medium risk, and prohibit AI for high risk compliance sensitive operations. This means you can't use AI where you need it most. The areas that would benefit from AI's speed and consistency (financial transactions, data access, change approvals) are exactly the areas compliance frameworks scrutinize.

Option 4: The Compensating Controls Stack Since you can't explain individual decisions, overcompensate with continuous monitoring, anomaly detection, and frequent audits. Document that you know you can't explain everything, but demonstrate how you contain risk through multiple overlapping controls. This is expensive. It might still fail audit.

None of these are good solutions. They're compromises between compliance requirements and AI capabilities.

The Questions Nobody Wants to Answer

Can you have HIPAA compliance without explainable access decisions?

Can you achieve SOC 2 without meaningful segregation of duties?

Can you maintain PCI-DSS with non-deterministic controls?

The honest answer might be "no." But organizations are deploying AI agents in regulated environments anyway, hoping the compliance frameworks adapt before the auditors show up.

The Uncomfortable Truth

We spent decades building compliance frameworks around systems we could explain. Deterministic processes. Clear decision chains. Documented approvals. Auditable controls.

AI agents are probabilistic black boxes that make contextual decisions at machine speed. Every decision is defensible in the moment and inexplicable in retrospect.

Either the compliance frameworks adapt, or organizations face a choice: deploy AI agents and risk compliance failures, or maintain compliance and forgo AI's benefits.

Most organizations are choosing the former and hoping auditors don't ask hard questions yet.

That's not a strategy. That's a gamble.

And unlike the infrastructure risks I wrote about before, this one comes with legal liability, regulatory fines, and failed audits. The bill is coming due.

When your auditor asks "why did your system do that?" and your honest answer is "I don't know, the AI decided," you'll understand why compliance in the age of AI agents isn't just a technical problem.

It might be unsolvable.

Comments

4

Like Comment Share

Add a comment...

No comments, yet.

Be the first to comment.

Start the conversation

Enjoyed this article?

Follow to never miss an update.

Andrew Storms

VP of Security | AI Security Governance | Enterprise Risk & Compliance | Trusted Advisor to CEOs & Boards

Follow

About
Accessibility
Talent Solutions
Questions?
Visit our Help Center.
Select Language
English (English)
Professional Community Policies
Careers
Marketing Solutions
Manage your account and privacy
Go to your Settings.
Privacy & Terms
Ad Choices
Advertising
Sales Solutions
Mobile
Small Business
Recommendation transparency
Learn more about Recommended Content.
Safety Center

LinkedIn Corporation © 2026